NATIVE AGENT 365 · PUBLIC CLOUD · 24 OCTOBER 2026

Verify tokens first.

Reject invalid requests at the edge. Retain Microsoft Agents SDK validation and caller/operation authorization behind the web application firewall.

JWT	EXPECTED VALUE AND STABILITY
Crypto/time	Bearer JWT; `RS256`, trusted OpenID/JWKS, valid `exp` / `nbf`. Refresh keys by `kid`; ignore token-supplied `jku`.
`tid` + `iss`	`tid=<TENANT_ID>`; exactly `iss=https://login.microsoftonline.com/<TENANT_ID>/v2.0`. Stable tenant/v2 profile, not a specific caller application's identity.
`aud`	Exactly `<BLUEPRINT_APP_ID>`: production target check, stable for the registration's lifetime. Shared by its instances, not unique to each Agent User.
`azp`	Observed Messaging Bot API Application: `5a807f24-c9de-44ee-a3a7-329e88a00ffc`. Its value may change in practice. Prefer non-blocking monitoring over a fixed allowlist: if other edge checks pass, allow a different `azp`, log, alert and investigate. Gateway authorization remains enforced.

Configuration: tenant ID from Entra overview; client ID from the blueprint app registration. Gateways may serve a blueprint or an instance. Audience routing isolates blueprints, not sibling instances; authorize subjects and operations separately.

The edge is the only public entry

HTTPS/443, `POST /api/messages`; backend ingress only from the edge. Require JWT/OIDC validation, not a regex. Edge egress: fixed tenant OpenID metadata and `jwks_uri` on 443. Bound body size, rate, concurrency and queues.

IP filtering is a temporary extra

`52.112.0.0/14`, `52.122.0.0/15`: published Teams IPv4 ranges shared by tenants, not a supported production callback allowlist. Changes can interrupt delivery. Handle IPv6 explicitly; trust the transport source/defined proxy chain, not arbitrary XFF.

Replies require outbound HTTPS

Gateway to `login.microsoftonline.com:443` and Teams `serviceUrl:443`. For outbound restrictions on this `serviceUrl`, see the proxy rule below. Replies/proactive sends use separate POSTs. Bind validated context to instance/channel/conversation; permit only approved HTTPS destinations, never arbitrary activity URLs.

Agent backends remain private

Gateway to Service Bus Private Endpoint asynchronously and a private HTTP(S) agent endpoint; VNet routing + private DNS. Only the agent calls MCP. Verify ACA Sandbox private publishing: VNet integration alone does not prove Private Link.

Optional outbound proxy rule: `smba.trafficmanager.net:443`, optionally path `/{geo}/<TENANT_ID>/v3/*` with L7/TLS inspection. This is routing, not authorization; service URLs can change. Sandbox egress can enforce a similar filter.

Useful links: JWT authorization · Teams serviceUrl · Sandbox egress · Teams IPs · IP limitations